3-й участник. Как минимизировать последствия во время атаки

Когда атака уже началась, главная задача — не искать «идеальное решение», а быстро снизить ущерб. Для этого действия должны идти по этапам.

Первый этап — подтвердить, что это именно атака

Не каждая перегрузка сайта является DDoS. Иногда сервис падает из-за обычного роста посещаемости, ошибки в коде, неудачного релиза, проблем с базой данных или неправильной настройки сервера.

Поэтому сначала нужно проверить признаки атаки. Например:

- резкий рост запросов за короткое время;
- много запросов к одному endpoint’у;
- большое количество однотипных User-Agent;
- странная география трафика;
- всплеск ошибок 502, 503, 504;
- рост нагрузки на CPU, RAM, сеть или базу данных;
- увеличение количества соединений;
- падение скорости ответа.

Cloudflare отмечает, что один из признаков DDoS — внезапное замедление или недоступность сервиса, но для подтверждения нужны данные traffic analytics, потому что похожие симптомы может дать и легитимный всплеск трафика.

Второй этап — определить тип атаки

Если забит интернет-канал, проблема находится на сетевом уровне. В этом случае локальный сервер может уже не видеть весь трафик, потому что канал перегружен до него. Нужно подключать провайдера, анти-DDoS или CDN.

Если перегружено приложение, например API или страница входа, нужно включать прикладные меры: WAF, rate limiting, CAPTCHA, challenge, временное отключение тяжёлых функций, кэширование.

Если перегружается база данных, нужно срочно выявить самые дорогие запросы и ограничить endpoint’ы, которые их вызывают.

Третий этап — включить фильтрацию и ограничение запросов

На уровне приложения применяют rate limiting. Это ограничение количества запросов от одного IP, подсети, пользователя, токена, сессии или API-ключа.

Пример: если обычный пользователь делает 10–30 запросов в минуту, а конкретный источник делает 5000 запросов, такой трафик можно ограничивать. Но лимиты нужно выбирать аккуратно, чтобы не заблокировать реальных пользователей за NAT, например офис, общежитие, мобильного оператора или корпоративную сеть.

Для веб-приложений включают WAF — Web Application Firewall. Он помогает фильтровать подозрительные HTTP-запросы, блокировать известные вредоносные шаблоны, ограничивать доступ к чувствительным endpoint’ам и применять managed rules. AWS в своих рекомендациях по DDoS-устойчивости прямо связывает защиту прикладного уровня с использованием AWS WAF вместе с edge-сервисами вроде CloudFront.

Четвёртый этап — уменьшить нагрузку на origin-сервер

Origin-сервер — это основной сервер приложения. Во время атаки его нужно максимально разгрузить.

Для этого можно:

- включить CDN;
- перевести статические файлы на кэширование;
- увеличить TTL для статического контента;
- временно отключить тяжёлые динамические блоки;
- включить режим статической заглушки для части страниц;
- ограничить поиск, фильтры, генерацию отчётов и другие тяжёлые операции;
- закрыть неиспользуемые endpoint’ы;
- ограничить доступ к админ-панели по IP или VPN.

Главная идея простая: всё, что можно отдать из кэша, не должно доходить до основного сервера.

Пятый этап — связаться с провайдером или хостингом

Если атака объёмная, локальные меры могут быть бесполезны. Когда канал забит до сервера, firewall на самом сервере уже поздно применять.

Нужно связаться с:

- хостинг-провайдером;
- интернет-провайдером;
- облачным провайдером;
- анти-DDoS-поставщиком;
- командой CDN/WAF.

Провайдер может включить фильтрацию выше по сети, перенаправить трафик через scrubbing center, временно ограничить вредоносные протоколы или помочь с blackhole routing. Но blackhole routing — крайняя мера: он может спасти сеть, но фактически делает атакуемый IP недоступным.

Шестой этап — включить кризисную коммуникацию

Во время DDoS часто забывают о пользователях. Это ошибка. Если сервис недоступен, нужно дать понятное сообщение.

Например:

«Сервис временно работает нестабильно из-за внешней сетевой атаки. Данные пользователей не затронуты. Команда восстанавливает доступность».

Важно не писать лишнего. Не нужно раскрывать технические детали защиты, IP-адреса, внутреннюю архитектуру, названия уязвимых компонентов. Но нужно показать, что ситуация контролируется.

Седьмой этап — сохранить доказательства

После атаки понадобятся логи. Их нельзя удалять.

Нужно сохранить:

- access logs;
- firewall logs;
- WAF logs;
- NetFlow/sFlow, если есть;
- метрики CPU, RAM, network;
- список атакуемых URL;
- временную шкалу атаки;
- правила, которые применялись для защиты;
- переписку с провайдером.

Это нужно для анализа, отчёта, возможного обращения в правоохранительные органы и настройки защиты на будущее.

Вывод третьей части: во время атаки нельзя действовать хаотично. Сначала подтверждаем инцидент, затем определяем тип атаки, включаем фильтрацию, разгружаем origin-сервер, подключаем провайдера, информируем пользователей и сохраняем логи.